

Cyber Risk Executive Summary

First National Bank (Fictional) · Prepared by Ameer Khan · 2026-09-22

Simulated organisation. First National Bank is fictional and every figure illustrative. This demonstrates analytical method and reporting format, not an assessment of any real institution.

\$19.58M

Total annualised loss expectancy

\$5.53M

Residual after controls

2.2 / 5.0

NIST CSF maturity

8

Vendors assessed

3

Overdue reassessments

Executive Overview

Across five modelled threat scenarios, First National Bank (Fictional) carries an expected annual cyber loss of **\$19.58M**. The largest single exposure is Ransomware at \$5.42M a year, with a one-in-ten-year loss of \$13.99M. A programme costing **\$1.51M annually** would remove \$14.05M of that exposure, leaving \$5.53M residual.

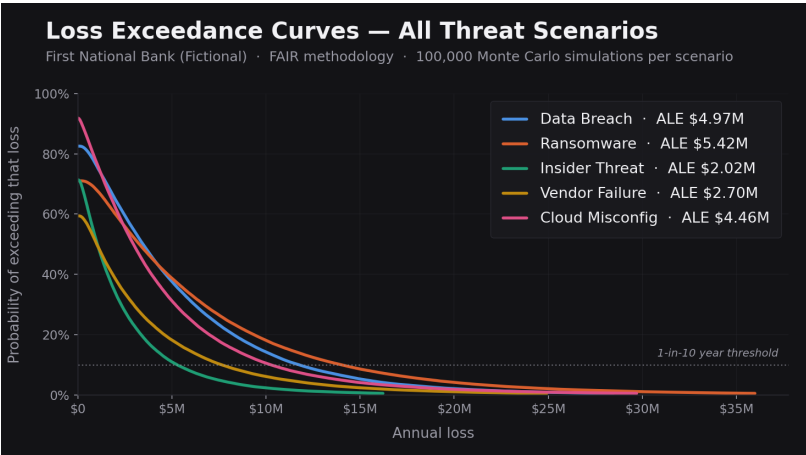
Control maturity is the constraint: **2.2 of 5.0** against NIST CSF 2.0, versus a target of 4, with **Respond** weakest at 1/5. 4 control gaps are open and 3 of 8 vendors are past their OSFI B-10 reassessment date. Governance and incident response are where low cost meets high consequence.

1. Quantified Risk Exposure

Each scenario is modelled with the FAIR method: annual event frequency drawn from a Poisson distribution, single-event loss from a log-normal fitted to a low/high range, summed across 100,000 simulated years.

Scenario	Expected annual loss	1-in-10 yr	Control cost	Residual ALE	ROSI
Ransomware	\$5.42M	\$13.99M	\$500.0K	\$1.35M	713%
Data Breach	\$4.97M	\$11.74M	\$350.0K	\$1.49M	894%
Cloud Misconfig	\$4.46M	\$10.24M	\$180.0K	\$892.8K	1,884%
Vendor Failure	\$2.70M	\$7.63M	\$200.0K	\$1.08M	711%
Insider Threat	\$2.02M	\$5.27M	\$280.0K	\$706.0K	368%
Portfolio total	\$19.58M	—	\$1.51M	\$5.53M	—

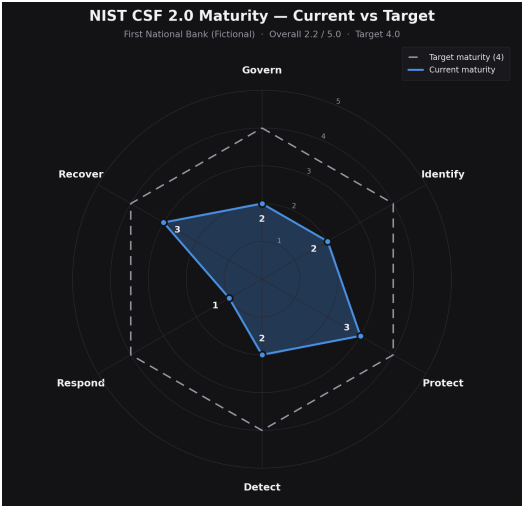
ROSI = (risk reduced – control cost) ÷ control cost. Effectiveness is assumed at 60–80% by scenario, not measured, and costs cover tooling only — so ROSI is an upper bound.



Loss exceedance curves. Read the curve at any dollar figure to get the probability that annual losses exceed it.

2. Control Maturity — NIST CSF 2.0

Function	Current	Target	Gap	Assessment
Govern	2	4	+2	Policy is three years old and was never re-approved. Risk appetite undocumented.
Identify	2	4	+2	Asset inventory hand-maintained and incomplete for cloud. Risk assessment informal.
Protect	3	4	+1	MFA and encryption deployed. Access reviews run but are not evidenced.
Detect	2	4	+2	Logging centralised, but no alert ownership and no defined thresholds.
Respond	1	4	+3	No documented incident response plan. OSFI 24-hour reporting path never walked through.
Recover	3	4	+1	Backups tested quarterly. RTOs defined for core banking only; wider BCP not exercised.



Current maturity against a target of 4 (managed and measured) across all six functions.

3. Recommended Actions

1. Ransomware — **Critical** (\$500.0K/yr programme)

The largest single exposure in the portfolio at \$5.42M expected annual loss, with a one-in-ten-year loss of \$13.99M. **\$4.06M/yr reduction at 75% assumed effectiveness, leaving \$1.35M residual. ROSI 713%.**

Action: Immutable offline backups tested quarterly; Network segmentation to limit lateral movement; Endpoint Detection & Response (EDR) on all devices.

Start this month: Confirm the \$500.0K sits in next year's budget line before the planning cycle closes.

[NIST CSF PR.AA-01](#), [DE.CM-01](#), [RC.RP-01](#) · [OSFI B-13](#) — [Technology Operations and Resilience](#)

2. Respond — **High** (low effort, about 6 weeks)

No response plan means chaos during an incident. OSFI's Technology and Cyber Security Incident Reporting advisory requires reportable incidents to be reported within 24 hours. RS.MA-01 is cited by 2 of the 5 modelled scenarios, which carry \$6.99M of combined annual expected loss. **Raises the weakest function from 1/5 towards the target of 4/5 and supports the \$6.99M of ALE that depends on it. No new tooling required.**

Action: Create an Incident Response Plan. Include the OSFI 24-hour incident reporting step from the Technology and Cyber Security Incident Reporting advisory. Run a tabletop exercise within 90 days.

Start this month: Assign an incident response lead and draft a basic contact tree today.

[NIST CSF RS.MA-01](#) · [ISO 27001 A.5.24](#), [A.5.26](#) · [SOC 2 CC7.3](#)

3. Third-party risk — **High** (about 90 days to clear the backlog)

1 vendor sits in the Critical tier (Rideau Infrastructure Group) and 3 are past the reassessment window for their tier (Gastown Data Works, Rideau Infrastructure Group, Acadia Payment Networks). OSFI B-10 expects monitoring proportionate to criticality. **\$1.62M/yr reduction against the \$2.70M third-party scenario. ROSI 711%.**

Action: Vendor security questionnaires and risk tiering (Critical/High/Medium/Low); Contractual security requirements in all vendor agreements; Continuous vendor monitoring and annual reassessment.

Start this month: Re-run the questionnaire for the overdue vendors before any contract renewal is signed.

[OSFI B-10](#) — [Third-Party Risk Management](#) · [NIST CSF GV.SC-07](#)

4. Third-Party Risk Snapshot

8 vendors assessed against an OSFI B-10 aligned questionnaire: 1 critical, 2 high, 3 medium, 2 low tier. **3 are past their reassessment date.**

Vendor	Service	Tier	Score	Crit. gaps	Reassessment
Rideau Infrastructure Group	Infrastructure	Critical	34	3	OVERDUE
Borealis Analytics	Analytics / AI	High	45	1	in 60d
Acadia Payment Networks	Payments	High	48	1	OVERDUE
Gastown Data Works	Analytics / AI	Medium	65	0	OVERDUE
MapleLedger Payments	Payments	Medium	72	0	in 320d
Cartier Ledger Systems	Software / SaaS	Medium	72	0	in 285d
NorthPeak Cloud Services	Cloud	Low	88	0	in 530d
Lakeshore Trust Software	Software / SaaS	Low	90	0	in 610d

5. OSFI Alignment

Guideline	Scope	Status in this assessment
B-13 (in force Jan 2024)	Technology and cyber risk management	Governance and detection gaps open; reporting path undefined
B-10 (in force May 2024)	Third-party risk management	Vendor tiering operating; 3 reassessments overdue
E-21 (full adherence Sep 2026)	Operational risk and resilience	Recovery tested; scenario testing of all critical operations due Sep 2027
Incident reporting advisory	Reportable technology and cyber incidents	24-hour path undocumented — closed by recommendation 2

Method and Limitations

Loss ranges are calibrated to published Canadian financial-sector breach benchmarks and read as the 5th and 95th percentile of a log-normal distribution, so the mean sits above the midpoint of the stated range. Each simulated year sums N independent loss draws, where N follows a Poisson distribution. Scenarios are modelled independently, though one event often triggers several. Control effectiveness is assumed, not measured. Read these as a decision-support range, not a forecast.